

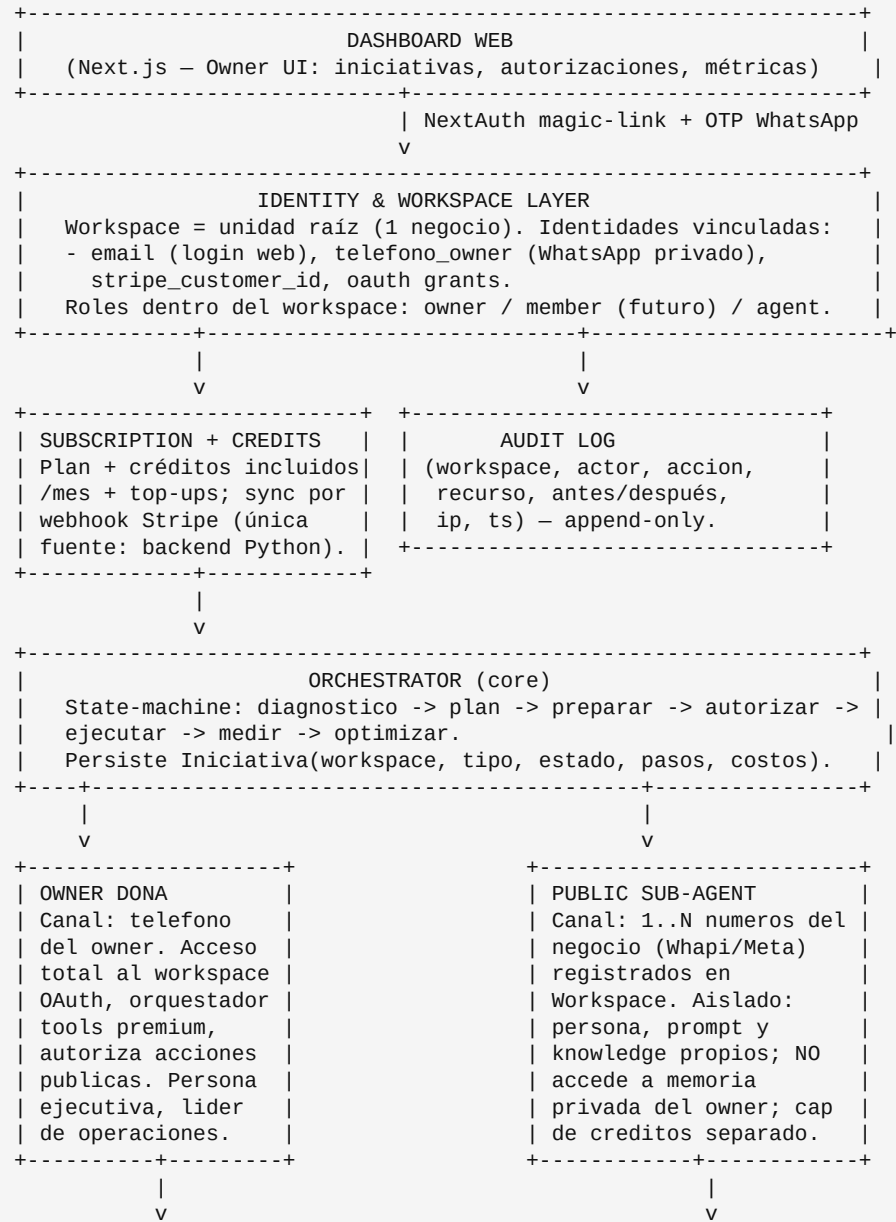
Dona — Plan Refinado v1

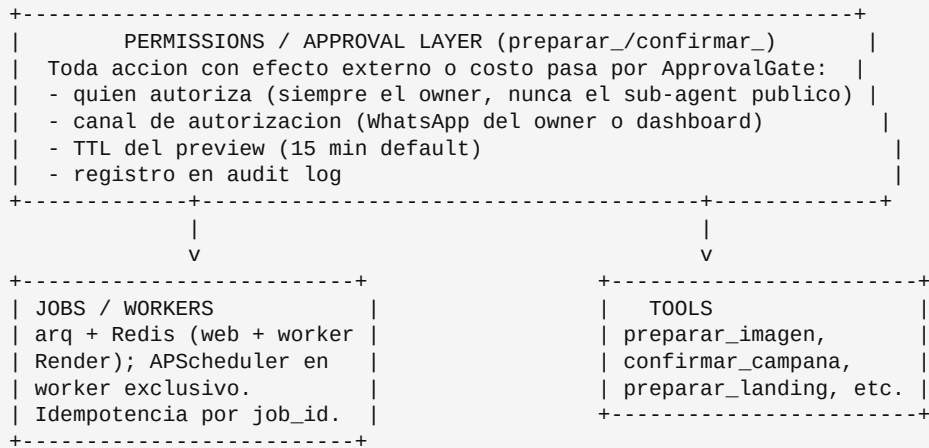
Fecha: 2026-04-29 · HEAD: 5b7d42d · Estado: planificación, no implementación · Modo: solo lectura.

Este documento es la versión refinada del plan de trabajo para Dona. Incorpora correcciones del owner: Workspace/Business como raíz; identidades email + teléfono vinculadas; monetización híbrida (suscripción mensual con créditos incluidos + top-ups); Stripe como única fuente de verdad en backend Python; posicionamiento de Dona como acelerador / orquestador autónomo premium para negocios (internamente: AI workforce / orchestration layer; nunca AGI público); cifrado campo-a-campo preservando índices y reporting; sub-agente público aislado por canal/Workspace.

A. Arquitectura objetivo v1

A.1 Vista de capas





A.2 Componentes

A.2.1 Identity / Workspace

- Workspace es la raíz: un negocio = un workspace.
- Tablas: **workspaces**, **workspace_identities** (tipo: email | phone_owner | stripe_customer | oauth_grant), **workspace_members** (rol).
- Vinculación email↔teléfono por **dobles verificación**: magic-link al email + OTP por WhatsApp al telefono_owner. Una identidad solo se vincula tras ambos retos.
- Cada request resuelve workspace_id antes de cualquier acción; no hay rutas globales sin workspace.

A.2.2 Subscription + Credits

- Plan en backend (**free** | **premium** | **pro** | **enterprise**) con campos: credits_incluidos_mes, tools_desbloqueadas, cap_sub_agentes_publicos, cap_canales.
- Sincronización **única** vía webhook Stripe en backend Python:
 - customer.subscription.created/updated/deleted → cambia plan del workspace.
 - invoice.payment_succeeded → renueva créditos incluidos del mes.
 - checkout.session.completed (mode=payment) → top-up (créditos extra).
- Landing redirige a Stripe Checkout y muestra estado, pero **no procesa efectos** (no acredita ni notifica WhatsApp).
- Cap de créditos por sub-agente público para limitar abuso desde canales públicos.

A.2.3 Owner Dona (privado)

- Atado al telefono_owner del workspace.
- Acceso total al estado del workspace, OAuth tokens, audit log, orquestador.
- Puede iniciar iniciativas, autorizar/rechazar previews, configurar el sub-agente público.
- Persona “líder de operaciones” — directa, premium, en español; nunca “asistente personal”.

A.2.4 Public customer-facing sub-agent (clave para la visión)

- **Aislamiento estricto**: cada workspace puede tener N canales públicos (números WhatsApp Meta/Whapi del negocio). Cada canal tiene su propio prompt, knowledge base, FAQ, persona, idioma, horario y cap de créditos.

- Tablas: **public_agents**(workspace_id, canal_id, persona_prompt, knowledge_ref, creditos_cap_mes, creditos_consumidos_mes, activo), **public_channels**(workspace_id, provider, phone_number_id, credenciales_cifradas).
- Routing del webhook entrante: provider + phone_number_id → workspace_id + public_agent_id. Si no matchea, va al canal owner (default).
- **Permisos restringidos:** solo lee public_agents.knowledge_ref y business.cliente_publico; **no** accede a Mensaje privado del owner ni a OAuth tokens.
- Puede capturar leads, agendar (si el workspace lo habilita), responder FAQ, escalar al owner.
- **No** puede ejecutar confirmar_* (campañas, pagos, mass mailings) — solo el owner autoriza.
- Cualquier acción que cobra créditos descuenta del cap del sub-agente, no del cap general del workspace.
- TCPA por canal: cada cliente final del workspace puede hacer STOP y queda registrado en tcpa_optouts(workspace_id, canal_id, telefono_cliente).
- Auditoría obligatoria: cada conversación pública genera fila en audit_log con tag *public_agent*.

A.2.5 Orchestrator

- Módulo nuevo agent/orchestrator/.
- Modelo Iniciativa(id, workspace_id, tipo, estado, plan_json, costos_estimados, costos_reales, pasos[], creado_por, autorizada_por, ts).
- Estados: borrador → diagnostico → plan_propuesto → autorizando → ejecutando → midiendo → optimizando → archivada/cancelada.
- Cada paso es un Job arq con preparar_/confirmar_ y autorización del owner.

A.2.6 Permissions / Approval layer

- Decorador / dependency requiere_aprobacion(scope, costo, ttl) que cualquier confirmar_* cruza.
- Aprobaciones expresadas en dashboard (botón) o WhatsApp del owner (confirmar/cancelar).
- Audit log obligatorio en cada aprobación con before/after.
- Sub-agente público nunca dispara aprobación; siempre escala al owner.

A.2.7 Jobs / Workers

- arq con Redis. Web service solo recibe webhooks, dispara encolado.
- Worker dedicado en Render (type: worker).
- APScheduler reside **solo** en worker (no en web) → permite escalar gunicorn web a 2+ workers en el futuro.
- Idempotencia por (workspace_id, tipo, dedup_key).

A.2.8 Audit log

- Tabla audit_log(id, workspace_id, actor_tipo, actor_id, accion, recurso_tipo, recurso_id, antes_json, despues_json, ip, ua, ts) append-only.
- Retención mínima 12 meses (CCPA/CPRA + due diligence).
- Owner puede exportar su audit log via dashboard (cumplimiento de derecho de acceso).

A.2.9 Dashboard (web premium)

- Vistas: Iniciativas en curso, Autorizaciones pendientes, Assets generados, Conexiones (OAuth), Sub-agentes públicos (configuración + métricas + cap de créditos), Plan + créditos, Audit log, Privacidad (export/delete).
- NextAuth con magic-link email; sesión bound a workspace_id resuelto en cada request.

A.3 Modelo de cifrado campo-a-campo

Política: **no cifrar todo**. Cifrar solo lo que es PII pesado o secreto, manteniendo índices, búsqueda y reporting funcionales.

Campo	Estrategia	Razón
Mensaje.content (WhatsApp privado del owner)	Fernet random + columna keywords_hash[] (HMAC) opcional para búsqueda futura	PII alto, raramente se busca exact-match
Mensaje.content (sub-agente público)	Fernet random	Igual al anterior
cliente.telefono (CRM público)	HMAC-SHA256 determinístico (telefono_hash) + Fernet random (telefono_cifrado)	Exact-match lookup; valor solo se descifra al mostrar
cliente.email	Igual al teléfono	Mismo patrón
cliente.nombre	Fernet random	Display only
Venta.monto, Gasto.monto, fechas, categorías	Texto plano	Reporting / agregaciones críticas
OAuth tokens (access/refresh)	Fernet (ya implementado)	Secreto de proveedor
WebAgent cookies	Fernet (ya implementado)	Secreto de sesión
public_channels.credenciales_cifradas	Fernet random	Tokens Meta/Whapi por canal
Workspace.telefono_owner	Texto plano + índice	Lookup primario del webhook
audit_log.antes_json / despues_json	Fernet random si contiene PII; metadata estructural plana	Auditoría legible para el owner
Datos del onboarding privado (proyectos, notas)	Fernet random	PII alto, display only

Reglas de migración: clave versionada (v1, v2...) — descifrar acepta múltiples; cifrar usa la actual. Helper hashed_lookup(secret, valor) para campos determinísticos. Tests verifican estabilidad del HMAC y rotación.

B. Backlog ejecutable

Convención: **Conf** = requiere confirmación humana antes de empezar.

Phase 0 — Security blockers

No se construye feature hasta cerrar esto.

T0.1 — Eliminar autenticación con password fake en landing

Objetivo	Cerrar el ATO trivial; usuario solo entra si controla el email + (opcional) WhatsApp.
Archivos probables	landing/auth.ts; landing/app/login/page.tsx; landing/app/api/auth/[...nextauth]/route.ts; nuevas rutas API para magic-link callback. landing/AGENTS.md recordatorio: revisar node_modules/next/dist/docs/ antes de cambiar APIs de Next.
Riesgo	Bloquear logins existentes durante el cambio; flujos de NextAuth EmailProvider requieren proveedor SMTP configurado.
Tests requeridos	landing/tests/auth.test.ts — magic-link rechaza tokens expirados; login solo con email no autoriza sin confirmar link; sesión incluye workspace_id y plan correctos.
Criterio de aceptación	Campo password desaparece; login pide email; magic-link entra al dashboard; tokens OTP de 15 min; rate-limit 5/h por email; pruebas pasan.
Requiere confirmación	Sí — decidir proveedor SMTP (Resend/Postmark/SES) antes.

T0.2 — Stripe webhook: firma obligatoria en producción

Objetivo	Rechazar 400 si STRIPE_WEBHOOK_SECRET falta y ENVIRONMENT=production.
Archivos probables	agent/billing.py:366-384; agent/main.py:2112-2151; tests/test_billing.py.
Riesgo	Si la env var está mal en Render, todo el flujo de créditos falla en vivo.
Tests requeridos	Webhook con env=production y sin secret → 500 al startup (no a runtime); con secret y firma inválida → 400; con firma válida → 200; idempotencia por stripe_session_id.
Criterio de aceptación	En prod no hay path que acepte payload sin firma; logs muestran rechazo explícito.
Requiere confirmación	No

T0.3 — Meta webhook: firma obligatoria en producción

Objetivo	Rechazar payloads sin META_APP_SECRET en prod.
Archivos probables	agent/providers/meta.py:131-150; tests/test_providers.py.
Riesgo	Si las env vars de Meta no están en Render, webhooks rebotan y mensajes se pierden.
Tests requeridos	env=production sin app_secret → falla startup; con app_secret y firma inválida → array vacío y log; firma válida → mensajes parseados.
Criterio de aceptación	Prod no tiene path "permitir sin firma".
Requiere confirmación	No

T0.4 — *INBOUND_WEBHOOK_SECRET sin fallback en producción*

Objetivo	Eliminar fallbacks derivados (de ADMIN_TOKEN o literal); en prod debe exigir env var.
Archivos probables	agent/inbound_tokens.py:30-42; tests/test_inbound_tokens.py.
Riesgo	Tokens emitidos previamente con secret derivado quedan inválidos → notificar al owner antes (rotación).
Tests requeridos	Prod sin secret → RuntimeError; secret válido → token verifica; cambio de secret → tokens previos fallan.
Criterio de aceptación	Prod sin secret no arranca.
Requiere confirmación	No

T0.5 — *Eliminar número personal hardcodeado en /voice/reenviar*

Objetivo	Mover +14076936023 a env var (VOICE_FORWARD_NUMBER); si no existe, devolver 404.
Archivos probables	agent/main.py:2165-2172.
Riesgo	Ninguno.
Tests requeridos	Con env var → TwiML correcto; sin env var → 404; admin auth opcional.
Criterio de aceptación	Ningún número personal aparece en código.
Requiere confirmación	No

T0.6 — *Disclaimer legal del landing alineado con realidad*

Objetivo	Quitar afirmaciones falsas (“encriptación end-to-end”, “no compartimos datos con terceros”) hasta que sean ciertas.
Archivos probables	landing/app/page.tsx:99 (whyDona.cards), :131 (faq.items), :142 (footer disclaimer); mismas claves en bloque EN.
Riesgo	Marketing pierde un selling point hasta que el cifrado universal esté listo (Phase 1).
Tests requeridos	Visual review; lint de strings prohibidas (end-to-end, extremo a extremo) en CI futuro.
Criterio de aceptación	Ninguna afirmación de seguridad sin sustento técnico.
Requiere confirmación	Sí — decidir wording exacto.

T0.7 — Audit dependencies del legacy (no borrar, mapear)

Objetivo	Dejar inventario de qué usa start.sh, enhanced/, mounts de docker-compose.yml, migration.py. No tocar.
Archivos probables	Documento de salida en docs/legacy-inventory.md (creación pendiente de autorización).
Riesgo	Ninguno (lectura sola).
Tests requeridos	N/A.
Criterio de aceptación	Lista con: archivo → quién lo importa, quién lo invoca en runtime, qué env vars depende, recomendación (mantener / mover / deprecar) sin borrar.
Requiere confirmación	Sí — autorización para crear el documento.

Phase 1 — Identity + billing foundation

T1.1 — Modelo Workspace + identidades vinculadas

Objetivo	Crear tablas workspaces, workspace_identities, workspace_members; resolver workspace_id en todo flujo.
Archivos probables	agent/memory.py (modelos); agent/identity/ (módulo nuevo); alembic/versions/002_workspaces.py; tests/test_identity.py.
Riesgo	Migración de usuarios existentes (cada teléfono actual = un workspace nuevo).
Tests requeridos	Crear workspace; vincular email; vincular teléfono con OTP; resolver workspace por teléfono / por email / por stripe_customer_id; conflicto (mismo email en dos workspaces) bloqueado.
Criterio de aceptación	100% del código que hoy hace where telefono == X se sustituye por resolución → workspace_id. Cero llamadas a tools sin workspace_id.
Requiere confirmación	Sí — decidir nombre del identificador raíz (workspace / business / cuenta).

T1.2 — Magic-link email + OTP WhatsApp

Objetivo	Vinculación de identidades requiere ambos challenges.
Archivos probables	landing/auth.ts; landing/app/api/auth/[...]; agent/identity/otp.py; agent/main.py (POST /identity/verify_otp); tests/test_identity_otp.py.
Riesgo	Phishing si magic-link no expira; UX adicional para vincular.
Tests requeridos	Magic-link expira a 15 min; OTP de 6 dígitos máx 5 intentos expira 10 min; vinculación sin ambos retos rechaza.
Criterio de aceptación	Login web + WhatsApp del mismo workspace coordinados.
Requiere confirmación	Depende de T0.1 (proveedor SMTP).

T1.3 — Migrar billing a fuente única backend Python

Objetivo	Deprecar landing/app/api/webhook/route.ts (procesamiento). Landing solo crea Checkout y redirige; backend Python procesa todo.
Archivos probables	landing/app/api/webhook/route.ts (vaciar a 410 Gone con instrucción de redirigir); agent/billing.py (handlers de subscription events); agent/main.py (sigue siendo /webhook/stripe); tests/test_billing.py.
Riesgo	Si Stripe Dashboard tiene endpoint del landing configurado, hay que actualizarlo antes del deploy.
Tests requeridos	customer.subscription.created → workspace.plan actualizado; invoice.payment_succeeded → créditos incluidos renovados; customer.subscription.deleted → plan free; checkout.session.completed mode=payment → top-up; doble entrega no duplica.
Criterio de aceptación	Solo el endpoint backend procesa eventos; el del landing devuelve 410 con mensaje.
Requiere confirmación	Sí — coordinar cambio de URL en Stripe Dashboard.

T1.4 — Plan + créditos híbrido

Objetivo	Tabla plans(codigo, creditos_incluidos_mes, tools_desbloqueadas[], cap_sub_agentes, cap_canales, precio_centavos, stripe_price_id). Asignación de créditos al renovar.
Archivos probables	agent/memory.py; agent/billing.py; alembic/versions/003_plans.py; tests/test_plans.py.
Riesgo	Corner case de upgrade/downgrade mid-cycle.
Tests requeridos	Upgrade prorratea créditos; downgrade no quita los ya consumidos; renovación mensual idempotente por (workspace_id, periodo).
Criterio de aceptación	Créditos se renuevan automáticamente; tools premium gateadas por plan.
Requiere confirmación	Sí — definir matriz exacta plan↔tools↔créditos.

T1.5 — Cifrado campo-a-campo (modelo del A.3)

Objetivo	Implementar Fernet versionado + helpers HMAC para campos determinísticos; migrar campos del A.3.
Archivos probables	agent/crypto.py (extender); agent/memory.py (decoradores/types); alembic/versions/004_encrypted_fields.py (agregar columnas _hash/_cifrado); tests/test_crypto_fields.py.
Riesgo	Migración de datos existentes (mensajes del owner) requiere job batch; índices nuevos (HMAC) necesitan creación cuidadosa.
Tests requeridos	Cifrar/descifrar con key v1 y v2; HMAC determinístico estable; búsqueda por cliente.telefono_hash retorna mismo registro post-cifrado.
Criterio de aceptación	PII identificada en A.3 está cifrada en DB; queries que dependen de ella siguen funcionando.
Requiere confirmación	Sí — confirmar matriz del A.3.

T1.6 — Audit log append-only

Objetivo	Tabla + helper audit(workspace_id, actor, accion, recurso, antes, despues) invocado por confirmar_*, login, cambios de plan, vinculación de identidades.
Archivos probables	agent/memory.py; agent/audit.py (nuevo); alembic/versions/005_audit_log.py; tests/test_audit.py.
Riesgo	Volumen — proyectar retención y particionado.
Tests requeridos	Insertar entry no permite update/delete (constraint o trigger); query por workspace_id + rango fechas; export funciona.
Criterio de aceptación	Cada acción crítica deja fila; export para CCPA disponible.
Requiere confirmación	No

Phase 2 — Premium product / Dashboard

T2.1 — Dashboard: Iniciativas + Autorizaciones

Objetivo	Vistas reales en /dashboard/iniciativas y /dashboard/aprobaciones.
Archivos probables	landing/app/dashboard/iniciativas/page.tsx; landing/app/dashboard/aprobaciones/page.tsx; API routes que llaman al backend; landing/lib/api.ts (cliente firmado por sesión NextAuth).
Riesgo	landing/AGENTS.md exige consultar node_modules/next/dist/docs/ antes de tocar APIs de Next — incorporar al checklist por PR.
Tests requeridos	Playwright/Vitest — owner ve solo iniciativas de su workspace; aprobar dispara confirmar_*; cancelar dispara cancelar_*.
Criterio de aceptación	Owner puede aprobar/cancelar desde web sin necesidad de WhatsApp.
Requiere confirmación	No

T2.2 — Dashboard: Conexiones OAuth

Objetivo	Iniciar/desconectar OAuth de Gmail, Calendar, Drive, Meta Business, Google Ads desde el dashboard.
Archivos probables	landing/app/dashboard/conexiones/page.tsx; backend agent/main.py (extender /auth/google/login con state firmado que incluya workspace_id y return_to=dashboard).
Riesgo	CSRF en OAuth callback.
Tests requeridos	State firmado con HMAC + nonce; callback verifica state; redirige al dashboard.
Criterio de aceptación	Owner conecta Gmail desde el dashboard y aparece “conectado”.
Requiere confirmación	No

T2.3 — Dashboard: Plan + créditos

Objetivo	Vista con plan vigente, créditos restantes, historial de transacciones, link a Customer Portal de Stripe.
Archivos probables	landing/app/dashboard/billing/page.tsx; API que llama a agent/billing.py:obtener_resumen filtrado por workspace.
Riesgo	Filtrar correctamente por workspace_id.
Tests requeridos	Owner solo ve sus créditos; llamada cross-workspace rechazada.
Criterio de aceptación	Owner ve y administra plan sin escribirle a Dona.
Requiere confirmación	No

T2.4 — Dashboard: Sub-agentes públicos (configuración)

Objetivo	CRUD de canales públicos + sub-agentes; persona, prompt, knowledge, cap de créditos, horarios, idioma.
Archivos probables	landing/app/dashboard/sub-agentes/page.tsx; agent/public_agents/ (módulo nuevo); agent/memory.py (public_agents, public_channels); alembic.
Riesgo	Prompt injection desde el owner que comprometa al sub-agente; aislamiento estricto del knowledge.
Tests requeridos	Crear canal Whapi; webhook entrante a ese número rutea al sub-agente correcto; sub-agente NO ve mensajes del owner; cap de créditos detiene generaciones cuando se agota.
Criterio de aceptación	Owner configura un sub-agente para su negocio, conecta un número, prueba conversación, ve métricas.
Requiere confirmación	Sí — confirmar diseño del knowledge base por canal (vector store por workspace, namespace public:{canal_id}).

T2.5 — Dashboard: Privacidad (CCPA real)

Objetivo	Export JSON descargable + delete real (soft 30 días, hard después) con verificación OTP doble.
Archivos probables	agent/privacy.py (nuevo); agent/main.py (reemplazar handlers manuales actuales); landing/app/dashboard/privacidad/page.tsx; alembic (deletion_requests).
Riesgo	Borrado afecta integridad referencial; coordinar con audit log (que sobrevive 30 días anónimos).
Tests requeridos	Export retorna todos los datos del workspace en JSON estructurado; delete soft enmascara PII; delete hard 30 días después purga; idempotencia.
Criterio de aceptación	Cumple plazo 45 días CCPA con UX self-service.
Requiere confirmación	Sí — decidir política de retención del audit log post-delete.

T2.6 — Reposicionamiento producto

Objetivo	Prompts, copy del landing, dashboard, mensajes proactivos describen Dona como acelerador autónomo para negocios, no asistente personal.
Archivos probables	agent/brain.py (system prompts en :1308, :3205 y otros); landing/app/page.tsx (i18n.ES y i18n.EN: hero, capabilities, whyDona, FAQ, footer disclaimer); agent/onboarding.py; agent/comandos_info.py (texto de ayuda); agent/legal_pages.py.
Riesgo	Prompt regression — re-validar tests de brain.py. Prohibir uso público de “AGI” / “AI workforce” en copy externo.
Tests requeridos	Snapshot tests del system prompt; lint de strings prohibidas (asistente personal, personal assistant, AGI) en landing/app/, agent/brain.py, agent/legal_pages.py.
Criterio de aceptación	Copy externo posiciona orquestación; copy interno puede usar “AI workforce” en docs internos.
Requiere confirmación	Sí — pasar copy nuevo en español/inglés antes de merge.

Phase 3 — Autonomous orchestration

T3.1 — Módulo orchestrator base

Objetivo	State-machine de iniciativas con persistencia.
Archivos probables	agent/orchestrator/__init__.py; agent/orchestrator/state.py; agent/orchestrator/iniciativa.py; agent/memory.py (modelo Iniciativa); alembic; tests/test_orchestrator.py.
Riesgo	Complejidad — empezar con 1 tipo de iniciativa simple antes de generalizar.
Tests requeridos	Transición válida entre estados; transición inválida rechazada; cancelación desde cualquier estado; reanudación tras restart (estado en DB, no en memoria).
Criterio de aceptación	Una iniciativa fluye end-to-end.
Requiere confirmación	No

T3.2 — Iniciativa: Diagnóstico de negocio

Objetivo	Primera iniciativa lista — analiza estado del workspace (datos OAuth, mensajes, ventas) y produce reporte con oportunidades.
Archivos probables	agent/orchestrator/iniciativas/diagnostico.py; prompt en agent/brain.py; tests/test_diagnostico.py.
Riesgo	Alucinaciones; usar Claude Sonnet 4.6 con grounding en datos reales.
Tests requeridos	Diagnóstico con mock de datos genera reporte estructurado; sin datos pide vincular fuentes.
Criterio de aceptación	Owner pide “diagnóstico” y recibe reporte con N oportunidades clasificadas por impacto.
Requiere confirmación	Sí — definir formato del reporte.

T3.3 — Iniciativa: Generación de assets de marca (imagen + copy)

Objetivo	Orquesta preparar_imagen + copy + variantes; owner aprueba bundle.
Archivos probables	agent/orchestrator/iniciativas/assets_marca.py; integraciones existentes en agent/creativos/.
Riesgo	Créditos altos por iniciativa — confirmar caps.
Tests requeridos	Bundle preview con N variantes; aprobar/rechazar bundle entero o parcial.
Criterio de aceptación	Owner pide “imágenes para mi campaña” y recibe set autorizable.
Requiere confirmación	No

T3.4 — Iniciativa: Atención automatizada en sub-agente público

Objetivo	Configura el sub-agente público para atender clientes finales con escalation al owner.
Archivos probables	agent/orchestrator/iniciativas/atencion_publica.py; agent/public_agents/runner.py; prompts.
Riesgo	TCPA — el sub-agente solo responde a mensajes entrantes, nunca proactivos sin opt-in explícito del cliente final.
Tests requeridos	Cliente escribe → sub-agente responde con FAQ; STOP → opt-out por canal; intento de mass mailing bloqueado.
Criterio de aceptación	Workspace activa atención y un cliente final recibe respuesta correcta sin tocar al owner.
Requiere confirmación	Sí — diseñar flujo de escalation (cuándo al owner, cuándo no).

T3.5 — Iniciativa: Campaña Meta Ads

Objetivo	preparar_campana_meta_ads → preview budget/audiencia/creatives → confirmar_ → trackear KPIs.
Archivos probables	agent/orchestrator/iniciativas/campana_meta.py; agent/integrations/meta_ads.py (nuevo); env vars.
Riesgo	Spend autorizado erróneamente; cap diario obligatorio en preview.
Tests requeridos	Preview muestra budget máximo; confirmar requiere aprobación humana explícita; cap diario aplica.
Criterio de aceptación	Owner lanza campaña pequeña en sandbox y ve métricas.
Requiere confirmación	Sí — Meta Business OAuth + cap default + sandbox account.

Phase 4 — Scale + observability

T4.1 — Render: web + worker separados

Objetivo	Agregar render.yaml con dos servicios; JOBS_BACKEND=arq obligatorio en prod.
Archivos probables	render.yaml (nuevo); Dockerfile (sin cambios o Dockerfile.worker); docs internos.
Riesgo	Doble billing en Render; coordinar APScheduler solo en worker.
Tests requeridos	Smoke de encolar→worker procesa; web sin scheduler no dispara dobles.
Criterio de aceptación	Jobs sobreviven restarts del web.
Requiere confirmación	Sí — autorización de costo Render.

T4.2 — Multi-worker gunicorn

Objetivo	Escalar web a 2+ workers; APScheduler ya está en worker.
Archivos probables	Dockerfile (-w 2); agent/scheduler.py (no-op si proceso es web).
Riesgo	Estado in-memory (dedupe, rate-limiter) duplicado — verificar que ya migró a Redis/DB.
Tests requeridos	Stress test con N requests concurrentes; dedupe sigue funcionando cross-process.
Criterio de aceptación	Web maneja 2x throughput.
Requiere confirmación	No

T4.3 — Alembic real + autogenerate

Objetivo	Snapshot del schema actual con --autogenerate; deprecate metadata.create_all() en runtime.
Archivos probables	alembic/versions/006_baseline_autogen.py; agent/main.py:lifespan (quitar inicializar_db directo, usar alembic).
Riesgo	Divergencias entre schema runtime y autogenerate — comparar antes de aplicar.
Tests requeridos	CI corre alembic upgrade head en DB vacía y compara con metadata actual.
Criterio de aceptación	Rollback funciona; nuevas columnas pasan por revisión.
Requiere confirmación	Sí — pre-flight comparación.

T4.4 — Observabilidad

Objetivo	Logs estructurados JSON, Sentry, alertas en jobs fallidos > N.
Archivos probables	agent/logging_config.py; agent/jobs/worker.py; env vars.
Riesgo	PII en logs — sanitizar antes de loguear.
Tests requeridos	Logger redacta texto de mensajes en nivel INFO; mantiene en DEBUG con flag.
Criterio de aceptación	Dashboards básicos en Sentry/Render.
Requiere confirmación	Sí — proveedor (Sentry/Datadog/Logtail).

T4.5 — CI: GitHub Actions

Objetivo	pytest + lint + type-check + build de landing en cada PR.
Archivos probables	.github/workflows/ci.yml (nuevo).
Riesgo	Secrets en CI — solo usar fixtures.
Tests requeridos	Workflow corre verde en branch limpia.
Criterio de aceptación	PR no merge sin CI verde.
Requiere confirmación	No

T4.6 — Auditoría de legacy (decisión, no borrado)

Objetivo	Con base en T0.7, decidir destino de start.sh, enhanced/, mounts del compose, migration.py. Decisiones individuales por cada uno.
Archivos probables	Depende de la decisión.
Riesgo	Borrar algo en uso → tests + búsqueda de imports antes de cualquier remove.
Tests requeridos	Full suite verde tras cada decisión aplicada.
Criterio de aceptación	Cada item del legacy tiene status (mantener / mover / deprecar fase X).
Requiere confirmación	Sí — uno por uno.

C. Tareas que requieren confirmación humana

ID	Por qué requiere confirmación
T0.1	Proveedor SMTP para magic-link
T0.6	Wording del nuevo disclaimer legal
T0.7	Autorización para crear docs/legacy-inventory.md
T1.1	Nombre del identificador raíz (workspace/business/cuenta)
T1.3	Actualizar URL del webhook en Stripe Dashboard sin downtime
T1.4	Matriz exacta plan ↔ tools ↔ créditos
T1.5	Confirmar matriz de cifrado del A.3
T2.4	Diseño del knowledge base por canal (vector store + namespace)
T2.5	Retención del audit log post-delete
T2.6	Copy nuevo ES/EN antes de merge
T3.2	Formato del reporte de diagnóstico
T3.4	Flujo de escalation owner ↔ sub-agente público
T3.5	Meta Business OAuth + sandbox + cap default
T4.1	Autorización de costo Render (worker separado)
T4.3	Pre-flight comparación schema runtime vs autogen
T4.4	Proveedor de observabilidad
T4.6	Decisiones individuales por cada item legacy

D. Decisiones que aún requieren confirmación (bloqueantes)

- **Nombre del identificador raíz:** Workspace / Business / Cuenta. Propongo *Workspace* (consistente con SaaS B2B).
- **Proveedor SMTP** para magic-link: Resend / Postmark / SES / Mailgun.
- **Matriz plan ↔ tools ↔ créditos:** precios del plan (los \$20/\$40 actuales del landing son fijos o propuesta?), créditos incluidos/mes por plan, qué tools desbloquea cada plan (orchestrator avanzado solo Pro? sub-agentes públicos solo Premium+?), cap de sub-agentes públicos por plan, precios de top-ups (mantener paquetes 100/500/2000 actuales?).
- **Confirmar matriz de cifrado** propuesta en A.3 — qué campos quedan en plano, cuáles HMAC, cuáles Fernet random.
- **Política del audit log post-delete:** anonimizar (mantener registro con actor=anonimo) vs hard delete. CCPA permite mantener si se justifica como necesario para seguridad/legal.
- **Flujo de escalation owner ↔ sub-agente público:** ¿cuándo escala? (preguntas fuera de FAQ, intent de queja, monto de transacción > X, palabras clave configuradas).

- **Knowledge base del sub-agente público:** vector store gestionado (pgvector ya está en uso indirecto?) o externo (Zep/Pinecone)?
- **Reposicionamiento del copy:** ¿hay versión preliminar del nuevo wording? Hero, capabilities, FAQ, disclaimer.
- **Política de retención** de mensajes privados del owner y públicos del sub-agente: ¿iguales? CCPA permite “mientras la cuenta esté activa”, pero por sub-agente público puede convenir un límite (90/180 días) por costo + privacidad.
- **Sandbox de Meta Ads / Google Ads:** ¿tenemos cuenta sandbox para integration tests?
- **Stripe Customer Portal:** ¿lo activamos para que el owner administre cancelación, métodos de pago y facturas sin código nuestro?
- **Decisión sobre enhanced/:** tras T0.7 (inventario), ¿lo fusionamos en agent/ (sistemas como tipo de iniciativa) o lo mantenemos paralelo?
- **Decisión sobre landing/app/api/whatsapp-webhook/route.ts:** ¿lo deprecamos (Meta apunta directo al backend Render) o lo mantenemos como proxy con headers filtrados? Lo segundo es útil para CDN/WAF; lo primero es más simple.
- **TCPA por sub-agente público:** ¿quién es responsable legal (Dona o el negocio dueño del workspace)? Asumimos negocio, pero el ToS/Privacy del workspace tiene que reflejarlo. Requiere revisión legal antes de Phase 3 T3.4.

Próximo paso: respuesta a las decisiones bloqueantes (especialmente 1, 3, 4, 6, 7, 14) antes de empezar a implementar. No habrá edits hasta autorización explícita por tarea.